

Cybersecurity Compliance Mapping: ISO/IEC 27001:2022 vs NIST CSF 2.0 vs India DPDP Act

Companion workbook:

[compliance_mapping_matrix.xlsx](#) (Summary,
Mapping_Matrix, Gap_Register, Framework_Overview,
Legend)

Prepared: 29 September 2026

1. Bottom line

- **ISO 27001 and NIST CSF 2.0 are highly compatible with each other** (average alignment 2.3 out of 3) and together cover the *security* half of the DPDP Act well.
- **They do not cover the *privacy* half.** Notice, consent, children's data, Data Principal rights and grievance redressal have essentially no counterpart in either framework (theme scores of 0.0 to 0.5 out of 3).
- Of 35 mapped requirements, only **5 (14%)** are strong overlaps with DPDP, **12 (34%)** partial, **14 (40%)** weak

or indirect, and **4 (11%)** are outright gaps.

- **An ISO 27001 certificate is strong evidence for Rule 6 (security safeguards) but is not evidence of DPDP compliance.** Roughly 12 of the 14 privacy-specific requirements need new controls, not relabelled existing ones.
- Timing matters: the Data Protection Board is already operating, Consent Manager provisions start around **November 2026**, and the bulk of obligations bite around **12-13 May 2027**.

2. Scope and method

Item	Detail
Frameworks	ISO/IEC 27001:2022 (clauses 4-10, Annex A, 93 controls); NIST CSF 2.0 (6 functions, 22 categories, 106 subcategories); DPDP Act 2023 and DPDP Rules 2025
Unit of mapping	35 requirement / control-objective rows across 9 themes
Scoring	0 = none, 1 = weak or indirect, 2 = partial, 3 = strong, scored for three pairs: ISO ↔ NIST, ISO ↔ DPDP, NIST ↔ DPDP
Status	Driven by the average of ISO ↔ DPDP and NIST ↔ DPDP, against editable

Item	Detail
	thresholds (Strong ≥ 2.5 , Partial ≥ 1.5 , Weak ≥ 0.5 , else Gap)

Scores are professional-judgement assessments, not regulator-endorsed equivalences.

3. Where the frameworks overlap

The security-safeguard controls line up almost one-to-one with **Rule 6** of the DPDP Rules:

DPDP Rule 6 safeguard	ISO 27001:2022	NIST CSF 2.0
Encryption, masking, obfuscation, virtual tokens	A.8.24, A.8.11, A.8.12	PR.DS-01, PR.DS-02
Access control	A.5.15-A.5.18, A.8.2, A.8.3, A.8.5	PR.AA-01 to PR.AA-05
Monitoring and logs	A.8.15-A.8.17	DE.CM, DE.AE
Continuity and backups	A.8.13, A.8.14, A.5.29, A.5.30	PR.DS-11, PR.IR-03, RC.RP

DPDP Rule 6 safeguard	ISO 27001:2022	NIST CSF 2.0
Processor contracts	A.5.19-A.5.23	GV.SC-01 to GV.SC- 10

Other solid overlaps: legal-obligations register (GOV-03), leadership accountability (GOV-01), risk assessment (RSK-01), audit and management review (RSK-03), and incident response process (INC-01).

Theme view (average scores, 0-3):

Theme	ISO ↔ NIST	ISO ↔ DPDP	NIST ↔ DPDP
Security Safeguards	3.0	2.2	2.2
Governance & Accountability	2.8	2.0	1.8
Risk & Assurance	2.8	1.5	1.5
Incident & Breach	3.0	1.5	1.5
People & Physical	3.0	1.5	1.5

Theme	ISO ↔ NIST	ISO ↔ DPDP	NIST ↔ DPDP
Supplier & Transfers	2.0	1.5	1.0
Asset & Data Management	2.2	1.2	0.8
Data Principal Rights	0.3	1.0	0.0
Consent & Notice	0.0	0.0	0.0

4. Gaps: what ISO 27001 and NIST CSF do not give you

Critical (new controls needed, highest penalty exposure)

1. **Notice** (S.5, Rule 3): standalone, itemised, purpose-specific notices.
2. **Consent lifecycle** (S.6, S.7, Rule 4): purpose-wise capture, withdrawal as easy as giving consent, Consent Manager integration.
3. **Children's data** (S.9, Rules 10-12): verifiable parental consent; no tracking, behavioural monitoring or targeted advertising to children.
4. **Grievance redressal and nomination** (S.8(10), S.13, S.14): Data Principals must use the fiduciary's

process before going to the Board.

5. **Breach notification** (S.8(6), Rule 7): notify the Board *and* each affected individual; detailed report to the Board within 72 hours. No harm threshold applies to the Act's trigger, unlike typical ISO/CSF severity-based incident classification.

High

- **Data principal rights** (S.11, S.12): access, correction and erasure workflows, including propagation to processors.
- **Personal data map** (AST-01): DPDP has no formal record-of-processing duty, but notices, rights and erasure cannot work without one.
- **Purpose limitation and minimisation** (AST-03): no CSF outcome; only a generic pointer in ISO A.5.34.
- **Retention and erasure logic** (AST-05, Rule 8): must reconcile erasure with the Rules' minimum log-retention requirement.

Medium / conditional

- **DPO or contact point** (S.8(9), S.10(2)(a)); India-resident DPO if designated a Significant Data Fiduciary.
- **DPIA, independent data audit, algorithmic due diligence** for Significant Data Fiduciaries (S.10, Rule 13).

- **Cross-border transfers** (S.16, Rule 15): restricted-country model, possible SDF localisation, stricter sector rules continue to apply.
- **Prescriptive details**: DPDP fixes a minimum log-retention period where ISO/CSF leave it to risk assessment.

Reverse gaps (in ISO/NIST but not required by DPDP): threat intelligence, physical security, information classification tiers, secure engineering detail, and NIST's Govern outcomes. These still support the "reasonable safeguards" standard in S.8(5) but will not be asked for by name.

5. Penalty exposure (Schedule to the Act)

Failure	Maximum penalty
Reasonable security safeguards (S.8(5))	INR 250 crore
Failure to notify a breach (S.8(6))	INR 200 crore
Children's data obligations (S.9)	INR 200 crore
Significant Data Fiduciary additional obligations (S.10)	INR 150 crore

Failure	Maximum penalty
Other breaches of the Act or Rules	up to INR 50 crore

Penalties are per violation, so one incident can stack across bands.

6. Recommended roadmap

Phase	Actions
Now to Nov 2026	Appoint DPO or contact; build personal data map on top of the asset register; add DPDP to the legal register and risk method; decide Significant Data Fiduciary likelihood; review Consent Manager strategy
Nov 2026 to Feb 2027	Implement consent and notice platform; DSR and grievance workflows; children's-data controls; update processor contracts; retention schedule
Feb to May 2027	Update IR playbook with Board and individual notification and 72-hour tracker; tabletop exercise; set log retention; DPIA cycle and independent audit if SDF; evidence pack

Phase	Actions
Ongoing	Fold DPDP into ISMS internal audit, management review and corrective action; monitor Gazette notifications (country restrictions, SDF designations, date changes)

Practical route: treat DPDP as an extension of the existing ISMS. Add a privacy layer (ISO/IEC 27701 is the natural bridging standard) rather than building a parallel programme, and update the Statement of Applicability with a Rule 6 crosswalk.

7. Caveats

- Mapping scores are judgement-based; validate with legal counsel and your auditor before using them as audit evidence.
- DPDP Rules were notified in November 2025 and are being phased in. Rule numbers, the minimum retention and grievance periods, and phase dates are drawn from public secondary commentary (sources differ by a day on the final date). **Verify against the Gazette text before relying on them.**
- Sector regulators (e.g. RBI, SEBI, IRDAI) may impose stricter requirements that continue to apply alongside DPDP.

- This is compliance analysis, not legal advice.